CASE STUDY

The PAN-OS GlobalProtect Authentication Bypass of 2026 (CVE-2026-0257), Qilin and INC Ransomware: A Case Study

A TeamStarWolf case study. Published 11 November 2026; every source checked as of that date.

Executive summary

This one landed on the people who keep the VPN up: the firewall and remote-access teams running Palo Alto Networks GlobalProtect so that staff can work from anywhere. On 13 May 2026 Palo Alto Networks told them that, in one specific configuration, an unauthenticated attacker could skip the portal and gateway login and open a VPN connection of their own [1] [2] (**Confirmed**). Within four days someone was trying it [5] (**Confirmed** as Rapid7's finding).

The flaw, CVE-2026-0257, rests on a cookie the appliance trusted without checking it properly (CWE-565) [1] [3] (**Confirmed**). CISA added it to the Known Exploited Vulnerabilities (KEV) catalog on 29 May with a three-day deadline [4] (**Confirmed**). By June, Arctic Wolf was investigating intrusions that began at the VPN and ended with Qilin ransomware across Windows domains [7] (**Confirmed** as Arctic Wolf's finding). In October, Unit 42 said it had observed attempted exploitation by the ransomware operators it tracks as Qilin and INC, and that attackers were using the flaw to get past multi-factor authentication (MFA) into VPN sessions [6] (**Confirmed** as Unit 42's statement).

Key facts at a glance

Field	Value
Product	PAN-OS GlobalProtect portal and gateway; Prisma Access; Siemens RUGGEDCOM APE1808 running PAN-OS Virtual NGFW. Panorama and Cloud NGFW not affected [1] [8]
Flaw	Authentication bypass leading to an unauthorized VPN connection; CWE-565; vendor maps CAPEC-114 [1] [3]
Precondition	Authentication override cookies enabled plus a specific certificate configuration [1]
Scores	Vendor CVSS v4.0 7.8 HIGH, urgency HIGHEST; NVD CVSS v3.1 9.1 CRITICAL; Siemens v3.1 9.3 [1] [3] [8]
Disclosed	13 May 2026, 16:00Z; CVE ID reserved 3 Nov 2025; found internally by Palo Alto Networks [1] [2]
Fixed	Hotfixes across PAN-OS 12.1, 11.2, 11.1 and 10.2; the advisory's fix-release timeline was updated on 14, 15, 16, 20 and 28 May 2026; Prisma Access 11.2.7-h13 and 10.2.10-h36 [1]
KEV	Added 29 May 2026, due 1 Jun 2026; known ransomware campaign use: Known [4]
Earliest exploitation	17 May 2026, per Rapid7 [5]
Ransomware named	Qilin (Arctic Wolf, Unit 42); INC (Unit 42 only); Settra (ReliaQuest, second-hand) [6] [7] [11]
Victims	None named in any opened source; Unit 42 lists eleven sectors without counts [6]

Key findings

- **One configuration choice decided exposure.** Only devices with authentication override cookies enabled and a particular certificate set-up were exposed [1] (**Confirmed**). Rapid7 gives the root cause as the cookie certificate being reused for another feature, which let forged cookies be trusted [1] [5] (**Confirmed** as Rapid7's analysis, consistent with the vendor's workaround).
- **The severity score moved under defenders' feet.** Rapid7 reports a first vendor score of CVSS v4 4.7, raised to 7.8 on 29 May, while NVD scores the same flaw 9.1 on CVSS v3.1 [3] [5] (NVD 9.1 **Confirmed**; the first 4.7 score is Rapid7's report, and the vendor's own timeline does not record the change).
- **Early probing was quiet; later intrusions were not.** In 8 of 10 affected Rapid7 customers the forged credential was accepted without a full VPN session and no lateral movement followed [5]; in June, Arctic Wolf saw intrusions end in domain-wide Qilin encryption [7], and Unit 42's October update describes lateral movement and staging for ransomware after the VPN session [6] (**Confirmed** as their findings).
- **The VPN bypass was paired with an old backup bug.** Unit 42 says the actors chained Veeam CVE-2023-27532, in KEV since 2023 [4] [6] (**Confirmed**).
- **Attribution is thinner than the headlines.** INC rests on Unit 42 alone and Settra on ReliaQuest alone; no government advisory opened for this study names either for this CVE; KEV records ransomware use without naming a group [4] [6] [9] [11] (**Inferred**).

Top recommendations

1. Move every GlobalProtect portal and gateway to a fixed PAN-OS build, upgrading those that share cookies together, and move unsupported releases to a supported fixed version [1] (**Confirmed** as the vendor's direction).
2. Until patched, use a certificate dedicated only to authentication override cookies, replacing any certificate that served other services, or disable authentication override [1] (**Confirmed**).
3. Treat patching as the start, not the end: terminate active GlobalProtect sessions, rotate domain admin, service and cloud-storage credentials and reset KRBTGT twice [7] (**Confirmed** as Arctic Wolf's guidance).
4. Hunt for Event ID 1102, PSEXESVC service creation, remote C$ writes, bursts of Type 3 logons, and VPN sessions from hosting providers or with "kali" or DESKTOP-style hostnames [7] (**Confirmed** as Arctic Wolf's guidance).
5. Check whether GlobalProtect profiles expose the management interface on ports 4443 and 3879, a misconfiguration Unit 42 added to this brief from its Lunar Peak incident response, and patch Veeam CVE-2023-27532 [4] [6] (**Confirmed** as Unit 42's guidance).

Scope and method

This brief covers CVE-2026-0257 from the CVE reservation in November 2025 to the record as it stood on 11 November 2026, and the Qilin and INC ransomware activity that sources tie to it. It does not retell the INC Ransom history beyond what the joint government advisory states, and it describes tradecraft at advisory level: no exploit steps, payloads, commands or indicator values are reproduced.

Grade	Meaning in this study
Confirmed	Stated in a primary opened for this study: the Palo Alto Networks advisory, the CVE, NVD and KEV records, the Siemens and government advisories, and the Unit 42, Rapid7, Arctic Wolf and Kaspersky reports as statements of their own findings
Reported	Known through journalism, or a vendor claim seen only second-hand
Demonstrated	Shown working by a researcher (Rapid7's public checker), or by this study's own check of the library's ATT&CK, CWE, CAPEC and D3FEND files
Inferred	This study's own reasoning from cited facts, labelled where it appears

Not opened: ReliaQuest's original post on X, the HHS Qilin threat profile (refused the request) and the ASD page for the INC advisory (timed out; the NCSC NZ copy of the PDF was used). The exact release date of the INC advisory was not checked.

Part 1: what happened

Date	Event	Sources	Grade
22 Aug 2023	Veeam CVE-2023-27532 enters KEV, ransomware use Known	[4]	Confirmed
3 Nov 2025	Palo Alto Networks reserves CVE-2026-0257	[2]	Confirmed
13 May 2026	Advisory published (16:00Z); CVE record published (18:15Z); NVD entry published	[1] [2] [3]	Confirmed
14 to 16 May 2026	Fix-release timeline updated for 10.2.16-h7 (14 May); 12.1.4-h6, 11.2.7-h14, 11.2.10-h7 (15 May); 10.2.13-h21 (16 May)	[1]	Confirmed
17 May 2026	Earliest exploitation Rapid7 MDR observed, from Vultr hosting; first alert on 18 May	[5]	Confirmed
20 May 2026	Fix-release timeline updated for 10.2.7-h34	[1]	Confirmed
21 May 2026	Second wave, from Dromatics Systems hosting; Rapid7 judges it "likely from the same threat actor"	[5]	Confirmed
28 May 2026	Fix-release timeline updated for 12.1.7, 11.1.15, 11.1.7-h6, 11.2.4-h17, 11.2.12; CISA SSVC decision: exploitation active, automatable no, technical impact total	[1] [2]	Confirmed
29 May 2026	Vendor updates exploitation status (17:15Z) to limited exploit attempts; KEV adds the CVE, due 1 Jun; Rapid7 publishes its analysis and a public checker; Rapid7 reports the vendor score was raised from 4.7 to 7.8	[1] [2] [4] [5]	Confirmed; score change per Rapid7 only; checker Demonstrated
3 Jun 2026	Vendor adds an FAQ	[1]	Confirmed
4 Jun 2026	Arctic Wolf bulletin on the CVE	[7]	Confirmed
5 Jun 2026	Unit 42 threat brief: active exploitation in early June, split at the 29 May proof-of-concept release	[6]	Confirmed
Jun 2026	Several intrusions with CVE-2026-0257 as initial access end in Qilin ransomware	[7]	Confirmed as Arctic Wolf's finding
9 Jun 2026	Siemens SSA-967325 V1.1 adds the CVE for RUGGEDCOM APE1808; Unit 42 adds Cortex XDR and XSIAM coverage	[6] [8]	Confirmed
11 Jun 2026	Arctic Wolf bulletin on increased exploitation	[7]	Confirmed
14 Jul 2026	Siemens V1.2 lists the remediation as V11.2.10-h7 through Siemens support	[8]	Confirmed
20 Jul 2026	Arctic Wolf Labs report links the CVE to Qilin; BleepingComputer says CISA flagged ransomware use the same day	[7] [14]	Confirmed; flag date Reported

Date	Event	Sources	Grade
21 Jul 2026	BleepingComputer cites more than 167,000 exposed GlobalProtect instances (Shadowserver)	[14]	Reported
9 Oct 2026	ReliaQuest says on X that Qilin and Settra are exploiting the flaw	[11] [12]	Reported
19 Oct 2026	Unit 42 reports attempted exploitation by Spikey Scorpius (Qilin) and Tarnished Scorpius (INC)	[6]	Confirmed
20 Oct 2026	Unit 42 adds verification and remediation guidance; Cybersecurity Dive and The Hacker News report	[6] [11] [13]	Confirmed; news Reported
26 Oct 2026	NVD record last modified; Unit 42 adds Idira PAM coverage	[3] [6]	Confirmed
10 Nov 2026	Kaspersky ranks Qilin first by share of leak-site victims in Q3 2026	[15]	Confirmed

Discrepancies in the record

- **The KEV date.** Unit 42, The Hacker News and Hackread give 13 May 2026 as the KEV addition date [6] [13] [18]. The KEV catalog, NVD and the CVE record all say 29 May [2] [3] [4] (**Confirmed**). 13 May is the disclosure date; this study uses 29 May (**Inferred**).
- **Two scores, two systems.** "Critical" in headlines is NVD's CVSS v3.1 9.1; the vendor's 7.8 is CVSS v4.0 [1] [3] (**Confirmed**). Both are real.
- **When the ransomware flag changed.** KEV shows Known today [4] (**Confirmed**); the date it changed was not checked [14].

Part 2: the technical record

The flaw, at advisory level. The GlobalProtect portal and gateway can issue and accept authentication override cookies so users need not log in again. Palo Alto Networks says an unauthenticated attacker can bypass security restrictions and establish an unauthorized VPN connection when those cookies are enabled (portal: generate or accept; gateway: accept) together with a specific certificate configuration [1] (**Confirmed**). Rapid7 explains the certificate condition: when the certificate used for the cookies is reused for another feature, a forged cookie is trusted [1] [5] (**Confirmed** as Rapid7's analysis, consistent with the vendor's workaround). The weakness is CWE-565, Reliance on Cookies without Validation and Integrity Checking, in the vendor, NVD and KEV records [1] [3] [4] (**Confirmed**).

The fixes and workarounds. Fixed builds are 12.1.4-h6 and 12.1.7; 11.2.4-h17, 11.2.7-h14, 11.2.10-h7 and 11.2.12; 11.1.4-h33, 11.1.6-h32, 11.1.7-h6, 11.1.10-h25, 11.1.13-h5 and 11.1.15; and 10.2.7-h34, 10.2.10-h36, 10.2.13-h21, 10.2.16-h7 and 10.2.18-h6 [1] (**Confirmed**). The fix regenerates cookies by a more secure method, so every user re-authenticates once [1] (**Confirmed**). The workarounds are a certificate used only for override cookies, or turning authentication override off [1] (**Confirmed**).

What exploitation looked like. Rapid7 saw two waves from hosting providers, which it judges "likely from the same threat actor" because of a consistent spoofed MAC address [5] (**Confirmed** as Rapid7's finding). Unit 42 says only a small share of probed devices established VPN sessions, and that June's early activity came from

an unidentified actor with no post-access behavior [6] (**Confirmed** as Unit 42's statement).

The intrusion record. Arctic Wolf's June cases show a full ransomware chain after the VPN [7] (**Confirmed** as Arctic Wolf's finding):

Stage	What Arctic Wolf saw
Persistence	Run keys and scheduled tasks
Remote access	AnyDesk, Ngrok, LogMeIn and MeshAgent
Credentials	LSASS dumping; NTDS.dit extraction through Install From Media
Discovery	SoftPerfect Network Scanner and NetExec
Lateral movement	PsExec and RDP
Defense impairment	Event logs cleared; Defender disabled
Exfiltration	Rclone, ProtonDrive and FileZilla, with MEGA the primary destination; Defender flagged Rclone as Behavior:Win32/SuspRclone.A
Impact	Veeam targeted before encryption; outcomes from encryption only to double extortion

Unit 42's October update adds MFA bypass into a VPN session, dual-use remote-management tools, RDP and SMB lateral movement, and one case that pivoted to vCenter, weakened the ESXi execInstalledOnly control and dumped credentials offline from a domain controller's virtual disk, out of reach of in-guest endpoint detection [6] (**Confirmed** as Unit 42's statement). The same actors chained Veeam CVE-2023-27532, a missing-authentication flaw (CWE-306) [4] [6] (**Confirmed**).

Part 3: who and why

Qilin. Arctic Wolf ties several June intrusions to Qilin and says varied tradecraft is "possibly suggesting multiple affiliates"; it assesses with moderate confidence that such intrusions are likely ongoing [7] (**Confirmed** as Arctic Wolf's assessment). Unit 42 tracks Qilin as Spikey Scorpius (also Agenda, Qilin, Qilin Team), a ransomware-as-a-service (RaaS) affiliate program using double extortion [10], and reports attempted exploitation of this CVE by it [6] (**Confirmed**). In ATT&CK, the payload is S1242 Qilin and G1050 Water Galura is the program's operator [16] (**Demonstrated**). Because the 2026 record describes affiliates, this study binds the exploitation to the software and names G1050 only as the operator (**Inferred**). The wider Qilin record, including the 2024 Synnovis and 2025 Asahi attacks, is in The Ransomware Ecosystem.

INC. Unit 42 names Tarnished Scorpius (also Gold Ionic, Inc Ransom), which emerged in mid-2023 and gains access through known vulnerabilities in public-facing applications [6] [10] (**Confirmed**). Unit 42 states no confidence level [6]. The joint ACSC, CERT Tonga and NCSC NZ advisory describes INC as RaaS since mid-2023, with double extortion, and lists compromised credentials, spear-phishing, known flaws in internet-facing devices and VPN gateways without MFA as entry points; it gives the aliases Tarnished Scorpion and GOLD IONIC and does not name CVE-2026-0257 [9] (**Confirmed**). ATT&CK holds G1032 INC Ransom, alias GOLD IONIC, and S1139 INC Ransomware [16] (**Demonstrated**).

Settra. ReliaQuest named Qilin and Settra on 9 October, with Cobalt Strike, BloodHound and SharpHound observed [11] [12] (**Reported**). Unit 42 is only "aware of" that reporting and does not adopt it [6] (**Confirmed**).

Why. No source states a motive beyond the ransomware business model: encryption, and in some cases data theft for double extortion [7] [9] (**Inferred**; encryption-only and double-extortion outcomes **Confirmed** as Arctic Wolf's finding).

Part 4: impact and response

Victims and sectors. No opened source names a victim of this exploitation, and none publishes a count of compromised organizations (**Inferred** from [5] [6] [7]). Unit 42 lists education, financial services, healthcare, high technology, hospitality, manufacturing, professional and legal services, government, transportation and logistics, utilities and energy, and wholesale and retail, with no counts or geographies [6] (**Confirmed**). Arctic Wolf gives no victim count, sectors or geographies [7] (**Confirmed**). Kaspersky ranks Qilin first by share of victims published on data leak sites for the second quarter running, at 15.39% in Q3 2026, ahead of The Gentlemen at 7.89% [15] (**Confirmed** as Kaspersky's statistic).

Exposure is not vulnerability. Shadowserver counted more than 167,000 exposed GlobalProtect instances and Shodan more than 172,000 fingerprinted addresses [14] (**Reported**). The vulnerable feature is off by default, so these counts are an upper bound on exposure; the share with the vulnerable configuration is unknown (**Inferred** from [1] [14]).

The vendor and the government record. Palo Alto Networks found the bug itself and updated its fix-release timeline five times between 14 and 28 May [1] (**Confirmed**). KEV's required action is to apply vendor mitigations, follow BOD 22-01 for cloud services, or stop using the product [4] (**Confirmed**).

Industrial reach. Siemens added the CVE to SSA-967325 for RUGGEDCOM APE1808 on 9 June and listed the remediation on 14 July; the advisory is silent on exploitation [8] (**Confirmed**). That is industrial reach of the bug, not evidence of industrial victims (**Inferred**).

Part 5: the defender and vulnerability-management view

A feature setting, not a version number, decided who was exposed [1] (**Confirmed**). Asset inventories that list PAN-OS versions but not GlobalProtect cookie and certificate settings could not answer the first question a triage team asked (**Inferred**). The score history adds a second trap: a team that ranked by the first CVSS v4 4.7 would have parked a flaw that was exploited days later [5] (**Confirmed**; ranking effect **Inferred**). KEV, the SSVC "active" decision and the vendor's HIGHEST urgency rating were better signals than the first score, though KEV and SSVC came on 29 and 28 May, eleven days after the first exploitation Rapid7 saw, and when the urgency rating was first set was not checked [1] [2] [4] [5] (**Inferred**).

The controls are the five top recommendations above. Two points sit beside them: ReliaQuest warns that patching alone may not remove access gained earlier [12] (**Reported**), and the vCenter pivot and offline credential dump put the hypervisor layer, not just the guests, in scope for monitoring [6] (**Confirmed** as Unit 42's statement; monitoring advice **Inferred**).

What is overstated and what is understated

- **Overstated:** a 13 May KEV date [6] [13]; "critical" without saying which scoring system [1] [3]; the Settra link, which Unit 42 does not adopt [6]; and exposure counts read as victim counts [14] (**Inferred** from the cited records).
- **Understated:** the vendor's "limited exploit attempts" [1] sits beside later domain-wide ransomware [7] and Unit 42's staging for it [6]; access gained before remediation can outlive the patch [12] (**Reported**); the vCenter pivot defeats in-guest endpoint detection [6]; and an industrial platform inherited the flaw [8] (**Confirmed**). With no victims named, the known incidents are a floor, not a count (**Inferred**).

MITRE mappings

This Part binds the verified record to MITRE ATT&CK v20.0 Enterprise, CWE, CAPEC and D3FEND. Names and tactics come from the library's `data/attack/technique_profiles.jsonl`, `groups.jsonl`, `software.jsonl`, `superseded_by.jsonl`, `technique_to_d3fend.jsonl` and `data/weaknesses/` files [16] (**Demonstrated**). No source names ATT&CK technique ids; each row is this study's mapping (**Inferred**). Revoked ids were resolved through `superseded_by.jsonl`: Clear Windows Event Logs (T1070.001) to T1685.005 and Disable or Modify Tools (T1562.001) to T1685 [16] (**Demonstrated**). No ATT&CK for ICS table applies: Siemens's APE1808 advisory shows the bug on an industrial platform, but no source describes an industrial victim or effect [8].

Groups, software and campaigns

ATT&CK has no object for Settra, AnyDesk, LogMeIn, MeshAgent, NetExec or SoftPerfect Network Scanner [16] (**Demonstrated**), so none is bound. No ATT&CK campaign covers this activity.

Object	ATT&CK id	Relationship to this record
Qilin	S1242	Deployed after CVE-2026-0257 access (Arctic Wolf, 20 Jul); reported by Unit 42 attempting exploitation (19 Oct) [6] [7]
Water Galura	G1050	Operator of the Qilin RaaS program only; not named as the exploiter [16]
INC Ransom	G1032	Unit 42's Tarnished Scorpius, reported attempting exploitation (19 Oct) [6] [10]
INC Ransomware	S1139	INC's payload; no source describes its deployment after this CVE [6] [16]
Rclone	S1040	Exfiltration, MEGA the primary destination (Arctic Wolf, 20 Jul) [7]
PsExec	S0029	Lateral movement (Arctic Wolf, 20 Jul) [7]
ngrok	S0508	Remote access tooling (Arctic Wolf, 20 Jul) [7]
Cobalt Strike	S0154	Observed by ReliaQuest (9 Oct), second-hand [12] (**Reported**)
BloodHound	S0521	BloodHound and its SharpHound collector observed by ReliaQuest (9 Oct), second-hand [12] (**Reported**)

ATT&CK Enterprise techniques

ID	Name	Tactic(s)	Dated event or report	Sources
T1190	Exploit Public-Facing Application	Initial Access	Exploitation of the GlobalProtect portal and gateway (Rapid7, from 17 May; KEV, 29 May)	[1] [4] [5]
T1606.001	Web Cookies	Credential Access	Forged authentication override cookie trusted (Rapid7, 29 May)	[1] [5]
T1133	External Remote Services	Persistence, Initial Access	Unauthorized VPN connection (vendor, 13 May); VPN sessions past MFA (Unit 42, 19 Oct)	[1] [6]
T1219	Remote Access Tools	Command and Control	AnyDesk, Ngrok, LogMeIn, MeshAgent (Arctic Wolf, 20 Jul); dual-use RMM (Unit 42, 19 Oct)	[6] [7]
T1547.001	Registry Run Keys / Startup Folder	Persistence, Privilege Escalation	Run-key persistence (Arctic Wolf, 20 Jul)	[7]
T1053.005	Scheduled Task	Execution, Persistence, Privilege Escalation	Scheduled-task persistence (Arctic Wolf, 20 Jul)	[7]
T1003.001	LSASS Memory	Credential Access	LSASS dumping (Arctic Wolf, 20 Jul)	[7]
T1003.003	NTDS	Credential Access	NTDS.dit through Install From Media (Arctic Wolf, 20 Jul); offline dump from a domain controller disk (Unit 42, 19 Oct)	[6] [7]
T1046	Network Service Discovery	Discovery	SoftPerfect Network Scanner and NetExec (Arctic Wolf, 20 Jul)	[7]
T1021.001	Remote Desktop Protocol	Lateral Movement	RDP (Arctic Wolf, 20 Jul; Unit 42, 19 Oct)	[6] [7]
T1021.002	SMB/Windows Admin Shares	Lateral Movement	SMB (Unit 42, 19 Oct); PsExec and remote C$ writes (Arctic Wolf, 20 Jul)	[6] [7]
T1569.002	Service Execution	Execution	PsExec, evidenced by PSEXESVC.exe, executing commands on remote systems (Arctic Wolf, 20 Jul)	[7]
T1685.005	Clear Windows Event Logs	Defense Impairment	Event logs cleared (Arctic Wolf, 20 Jul)	[7]
T1685	Disable or Modify Tools	Defense Impairment	Defender disabled (Arctic Wolf, 20 Jul); hypervisor controls weakened (Unit 42, 19 Oct)	[6] [7]
T1567.002	Exfiltration to Cloud Storage	Exfiltration	Rclone and ProtonDrive to cloud storage, MEGA the primary destination (Arctic Wolf, 20 Jul)	[7]
T1486	Data Encrypted for Impact	Impact	Qilin across Windows domains (Arctic Wolf, 20 Jul)	[7]
T1490	Inhibit System Recovery	Impact	Veeam targeted before encryption (Arctic Wolf, 20 Jul)	[7]
T1210	Exploitation of Remote Services	Lateral Movement	Veeam CVE-2023-27532 chained (Unit 42, 19 Oct)	[4] [6]

Fit notes (**Inferred**): T1569.002 rests on Arctic Wolf's statement that PsExec, evidenced by PSEXESVC.exe, executed commands on remote systems. The Unit 42 half of T1003.003 assumes the offline dump from the domain controller's virtual disk targeted the NTDS database; Unit 42 says only that it yielded domain-wide credentials. T1490 is the nearest fit for targeting backup infrastructure; the sources do not say how backups

were impaired. T1210 assumes the Veeam server was reached from inside the network. The vCenter pivot itself is not bound because the sources do not say how it was done.

CWE and CAPEC

CWE	Name	Where it is assigned	Sources
CWE-565	Reliance on Cookies without Validation and Integrity Checking	CVE-2026-0257 (vendor, NVD, KEV)	[1] [3] [4]
CWE-306	Missing Authentication for Critical Functionality	Veeam CVE-2023-27532 (KEV)	[4]

CAPEC	Name	Via	Where it meets the record
CAPEC-114	Authentication Abuse	Vendor mapping	The authentication bypass [1]
CAPEC-226	Session Credential Falsification through Manipulation	CWE-565	A forged cookie accepted as a session credential [5] (**Inferred** fit)
CAPEC-39	Manipulating Opaque Client-based Data Tokens	CWE-565	The cookie as a client-held token [5] (**Inferred** fit)

The library relates CAPEC-31 to CWE-565 as well, and CAPEC-12, -36, -62, -166 and -216 to CWE-306; none meets this record at advisory level [16] (**Demonstrated**). See the CWE Reference and CAPEC Reference.

D3FEND countermeasures

D3FEND countermeasure	Techniques the library maps it to (from this study)	Where it meets the record
Session Termination	T1133, T1021.001	Terminate GlobalProtect sessions after patching [7]
Credential Rotation, Credential Revocation	T1606.001, T1003.003	Rotate domain admin, service and cloud-storage credentials; reset KRBTGT twice [7]
Reissue Credential, Authentication Cache Invalidation	T1606.001, T1003.003	The fix regenerates cookies and forces one re-authentication [1] (**Inferred** fit)
Multi-factor Authentication	T1606.001, T1003.003	Mapped by the library, yet the forged cookie bypassed MFA [6]
User Geolocation Logon Pattern Analysis	T1190, T1210, T1219, T1021.001, T1567.002	Hosting-provider VPN sources [5] [7] (**Inferred** fit)
Outbound Traffic Filtering	T1219, T1567.002	Rclone to MEGA; RMM tools [7] (**Inferred** fit)
Restore File	T1486, T1547.001	Backups targeted before encryption [7] (**Inferred** fit)

The vendor's dedicated-certificate workaround corresponds to Certificate Rotation, which the library does not relate to these techniques [1] [16] (**Inferred**). See the D3FEND Reference.

Navigator layer

The study's techniques are saved as an ATT&CK Navigator layer pinned to ATT&CK v20, `navigator/library-layers/palo-alto-pan-os-cve-2026-0257.json` (open in Navigator), listed on the Navigator layers page. Each technique appears under every tactic in its library profile. Scores: 75 for behavior in the vendor advisory or the KEV record, 50 for a vendor threat-intelligence report, 25 for an inexact fit. Each technique's comment names its source numbers.

Cross-cutting themes

- **The VPN is the front door, and this time the lock trusted a forged key.** In 2024 the way into Change Healthcare was a remote-access portal without MFA; the Healthcare Threat Watchlist records VPN and edge access as the recurring way in. In 2026 a forged cookie skipped MFA on the gateway itself [6] [17] (**Inferred**).
- **Edge bugs feed the extortion economy.** Like Cl0p's file-transfer campaigns, an edge flaw became a ransomware supply line within weeks [7] (**Inferred**).
- **Old KEV entries still matter.** A 2023 backup flaw was chained after a 2026 VPN flaw [4] [6] (**Confirmed** as Unit 42's statement).
- **Advisories keep moving.** The fix list, the exploitation status, Siemens's product scope and the named actors all changed after first publication [1] [6] [8] (**Confirmed**).

Sources

All sources were opened on 11 November 2026.

#	Source	URL	Opened	Grade
1	Palo Alto Networks, CVE-2026-0257 PAN-OS: GlobalProtect Authentication Bypass Vulnerabilities, 13 May 2026, updated 3 Jun 2026	security.paloaltonetworks.com/CVE-2026-0257	2026-11-11	Confirmed
2	CVE Program record CVE-2026-0257 (CNA Palo Alto Networks, with CISA ADP)	cveawg.mitre.org/api/cve/CVE-2026-0257	2026-11-11	Confirmed
3	NVD, CVE-2026-0257, page and 2.0 API record	nvd.nist.gov/vuln/detail/CVE-2026-0257	2026-11-11	Confirmed
4	CISA, Known Exploited Vulnerabilities catalog JSON, version 2026.11.10 (CVE-2026-0257 and CVE-2023-27532)	cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json	2026-11-11	Confirmed
5	Rapid7, Rapid7 observed exploitation of PAN-OS GlobalProtect authentication bypass vulnerability (CVE-2026-0257), 29 May 2026	rapid7.com/blog/post/etr-rapid7-observed-exploitation-...	2026-11-11	Confirmed; checker Demonstrated
6	Unit 42, Active Exploitation of May 2026 PAN-OS CVE-2026-0257, 5 Jun 2026, updated through 26 Oct 2026	unit42.paloaltonetworks.com/active-exploitation-of-pan-os-cve-2026-0257/	2026-11-11	Confirmed
7	Arctic Wolf Labs, Cookie Crumbles: exploitation of CVE-2026-0257 leads to Qilin ransomware, 20 Jul 2026	arcticwolf.com/resources/blog/exploitation-of-cve-2026-0257-...	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
8	Siemens ProductCERT, SSA-967325 (RUGGEDCOM APE1808), V1.1 9 Jun 2026, V1.2 14 Jul 2026	cert-portal.siemens.com/productcert/html/ssa-967325.html	2026-11-11	Confirmed
9	ACSC, CERT Tonga and NCSC NZ, INC Ransom Affiliate Model Enabling Targeting of Critical Networks (PDF, 2026; release date not checked)	ncsc.govt.nz/assets/guidance/Documents/INC-Ransom-...	2026-11-11	Confirmed
10	Unit 42, Threat actor groups tracked by Palo Alto Networks Unit 42	unit42.paloaltonetworks.com/threat-actor-groups-...	2026-11-11	Confirmed
11	Cybersecurity Dive, report on ransomware groups targeting the Palo Alto Networks flaw, 20 Oct 2026	cybersecuritydive.com/news/ransomware-targeting-...	2026-11-11	Reported
12	Infosecurity Magazine, report on ReliaQuest's warning about the GlobalProtect flaw, 12 Oct 2026	infosecurity-magazine.com/news/palo-alto-vpn-vulnerability-target	2026-11-11	Reported
13	The Hacker News, Qilin and INC ransomware groups exploit the PAN-OS flaw, 20 Oct 2026	thehackernews.com/2026/10/qilin-and-inc-ransomware-groups-exploit.html	2026-11-11	Reported
14	BleepingComputer, Critical GlobalProtect VPN bug now exploited in ransomware attacks, 21 Jul 2026	bleepingcomputer.com/news/security/critical-globalprotect-vpn-bug-...	2026-11-11	Reported
15	Kaspersky Securelist, Q3 2026 PC and IoT malware statistics, 10 Nov 2026	securelist.com/malware-report-q3-2026-pc-iot-statistics/121843/	2026-11-11	Confirmed
16	TeamStarWolf library data: `data/attack/technique_profiles.jsonl`, `groups.jsonl`, `software.jsonl`, `superseded_by.jsonl`, `technique_to_d3fend.jsonl` (ATT&CK v20.0), and `data/weaknesses/cwe.jsonl` and `capec.jsonl`	github.com/TeamStarWolf/TeamStarWolf/tree/main/data/attack	2026-11-11	Demonstrated
17	TeamStarWolf, Change Healthcare 2024 and Healthcare Threat Watchlist case studies	/case-studies/HEALTHCARE_THREAT_WATCHLIST.md	2026-11-11	Confirmed
18	Hackread, Qilin and INC exploit Palo Alto VPN flaw in ransomware attacks, 22 Oct 2026	hackread.com/qilin-inc-exploit-palo-alto-vpn-flaw-...	2026-11-11	Reported

Not opened, so not cited as sources: ReliaQuest's original post on X (refused the request), the HHS Qilin threat profile PDF (refused the request), and the ASD page for the INC advisory (timed out).

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- The Ransomware Ecosystem, Change Healthcare 2024, Healthcare Threat Watchlist, Cl0p File Transfer 2023, ICS Attacks and Advisories 2024 to 2026, The Year 2026 in Intrusions, Timeline
- Other 2026 edge-appliance studies: The Ivanti Connect Secure zero-day chain, The Cisco Catalyst SD-WAN authentication bypass, The Citrix NetScaler zero-days
- Threat Actors, Malware Families, Notable Incidents
- CVE Reference, CWE Reference, CAPEC Reference, D3FEND Reference
- Edge Device Security Reference, PAN-OS, Palo Alto Networks, Vulnerability Management Reference, Vulnerability Prioritization Reference
- Groups: G1032 INC Ransom, G1050 Water Galura
- Software: S1242 Qilin, S1139 INC Ransomware, S1040 Rclone, S0029 PsExec, S0508 ngrok, S0154 Cobalt Strike, S0521 BloodHound
- Techniques: T1190 Exploit Public-Facing Application, T1606.001 Web Cookies, T1133 External Remote Services, T1003.003 NTDS, T1567.002 Exfiltration to Cloud Storage, T1486 Data Encrypted for Impact
- CAPEC: CAPEC-114, CAPEC-226, CAPEC-39
- Navigator layers, including this study's layer, palo-alto-pan-os-cve-2026-0257.json
- The Team Star Wolf Intelligence Hub
- All case studies